

Más allá del Checklist: El Auditor como Guardián del Valor y la Ética

El enfoque tradicional de la auditoría de TI suele percibirse como una función policial que busca errores. Esta propuesta invita a ver las normas (ISO, COBIT, NIST) no como restricciones, sino como un marco ético que protege el activo más importante de una organización: la confianza de sus usuarios. Cumplir una norma técnica es, en el fondo, una decisión ética de proteger datos, garantizar la disponibilidad de servicios críticos e impactar positivamente en la sociedad.

Flujo de Valor y Riesgo



La identificación de activos críticos comienza entendiendo qué procesos mantienen viva a la organización (ITIL). No todos los activos valen lo mismo; por ello, la evaluación de vulnerabilidades requiere una mentalidad basada en el riesgo (NIST), analizando qué pasaría si un activo pierde su confidencialidad, integridad o disponibilidad. La priorización de controles no es aleatoria: el Anexo A de la norma ISO 27001 nos da un catálogo estructurado. En lugar de implementarlos todos a ciegas, elegimos aquellos que mitigan los riesgos más altos, mientras que COBIT asegura que estas decisiones tecnológicas se traduzcan en gobernanza corporativa, equilibrando el riesgo con el rendimiento.

Caso de la Vida Real (Simulación basada en incidentes reales)

En el caso simulado de "MediCareTech", la dirección desestimó marcos normativos (ITIL, NIST) y rechazó recomendaciones de auditoría sobre segmentación y control de acceso (ISO 27001) por considerarlas costosas. Como consecuencia, un ataque de *ransomware* iniciado por *phishing* logró propagarse lateralmente hasta los servidores quirúrgicos críticos. Esto provocó la cancelación de procedimientos médicos y puso en riesgo la vida de los pacientes, demostrando empíricamente que la omisión de controles de TI no es un simple fallo técnico, sino una grave negligencia ética y de gobierno corporativo.

Aprendizajes para futuras auditorías

Al final del día, el mayor aprendizaje es que los auditores no podemos limitarnos a hablar de servidores, normativas o jerga técnica; tenemos que traducir esos hallazgos al idioma de las personas y del negocio. Más que simplemente marcar casillas para ver si cumplimos con la norma ISO o el NIST, nuestro verdadero valor está en saber contar la historia de lo que pasaría en la vida real si no actuamos a tiempo. Un buen auditor no es el que solo busca errores, sino un aliado que ayuda a proteger el propósito, la confianza y el lado más humano de la organización.

Referencias

- AXELOS. (2019). *ITIL foundation: ITIL 4 edition*. TSO (The Stationery Office).
- Cascarino, R. E. (2012). *Auditor's guide to IT auditing* (2nd ed.). John Wiley & Sons.
- ISACA. (2018). *COBIT 2019 framework: Introduction and methodology*. ISACA.